Security Self-Assessment

Implemented permission tiers, controls, residual risks | 20 October 2026 | v9.1

Assessment boundary: CashBridge v9.1 is a functional financial-agent prototype using synthetic SME cases and mock lender/payment paths. Statements below reference the submitted code and archived checks; they are **not** a production certification or an independent penetration test.

1. PERMISSION TIERS: WHAT THE AGENT MAY DO

TIER	ACTION CLASS	AGENT / HUMAN BOUNDARY
L0 Read	View permitted balances, documents, inbox and payment history.	Session, tenant and role checked; no blanket access.
L1 Analyse	Reconcile, 13-week forecast, buyer scoring, financing comparison, simulation; unsigned contract drafts from a fixed clause library.	Named tool must be on the agent allowlist; every decision logged. Drafts are never signed.
L2 Internal	Write/lock internal evidence; propose learning/model updates.	Deterministic matches may proceed; ambiguous writes and decisions require a named human.
L3 External	Release a financing pack / send simulated financing communication.	Coordinator only; Director confirms the exact action and payload with a time-limited, single-use, action-bound OTP. No autonomous submission.
L4 Funds	Transfer funds, change payee, execute payment.	**Always forbidden.** No money-movement tool on any agent allowlist.

Outside the agent tiers (internal records, L2): publishing the audit-log Merkle root is a digest of records the SME already holds. It runs automatically after release and after the lender's decision (best effort: a failure never blocks the human action but is written to the audit log, shown on the Trust page and fails the lender's anchor check), and an Accountant or Director may publish one manually **without** the pack-release OTP; the publisher is recorded. Registering a funded invoice on the consortium register is performed inside the lender's credit decision. Neither can release a pack, change a payee or move money.

2. SEPARATION OF DUTIES AND RELEASE PATH

ACTOR	CAN PERFORM	CANNOT PERFORM
Accountant	Analyse; provide evidence; prepare/rework funding pack; draft contracts for counsel.	Approve own release or act as lender.
Director	Review/reject; OTP-confirm pack release; approve governed model changes.	Bypass source gate, OTP or money prohibition.
Lender human	Read released case; request/open evidence; verify hashes, on-chain register and anchors; record mock credit decision.	Access unreleased cases; fund an invoice another consortium lender holds; disburse real funds.
Finance Autopilot	Analyse → verify → price → stress-test → draft → request approval.	Submit pack itself; approve, lend or transfer.

3. SECURITY ENFORCEMENT POINTS AND INSPECTION PATHS

- **Tool gate:** registered tier, per-agent allowlist, confidence/human checks and logged denial (config/tool_allowlist.py; security/permission_gatekeeper.py).
- **Identity + release:** signed role/tenant sessions; Director OTP tied to the approval payload; released-case lender scope (security/auth.py; security/otp_verifier.py; agents/coordinator.py).
- **Document custody:** type by bytes, 10 MB, **PDF active-content screen** (JavaScript, launch, embedded files, XFA, auto-actions; hex-escaped names and compressed object streams inspected) before parsing or storage; SHA-256; AES-256-GCM bound to tenant/case/file; audited view; lender must open the current file to accept (security/pdf_screen.py; workspace/evidence_vault.py).
- **Financial integrity:** 3-way invoice matching, local duplicate registry, source attestations, fail-closed funding gate, click-to-source provenance (core/financing_gate.py; core/provenance.py).
- **Consortium ledger (optional, in-process EVM):** Vyper contracts executed by py-evm/eth-tester inside the server; other lenders are simulated accounts. Invoice register keyed by HMAC commitments (no invoice data on chain) refuses a second lender at funding. Modes (CASHBRIDGE_CHAIN): *evm* (default in DEMO) fails closed, i.e. any register error refuses funding; *required* (default in PRODUCTION) also refuses funding when the module is absent; *off* lets funding proceed and records 'register not checked' in the audit log and lender history (chain/ledger.py; ui/backend_real.py).
- **Conditional control:** the data reliability gate is always on in PRODUCTION; in DEMO it is off unless CASHBRIDGE_REQUIRE_DATA_GATE=1 (core/financing_gate.py).

Design rule (as implemented and tested, not a proof): document and message text is parsed as data only; no code path lets it grant a role, register a tool, skip an evidence check, confirm an L3 action or reach an L4 tool. The adversarial cases in section 5 exercise these paths. Refusals are written to the hash-chained audit log; its Merkle root is anchored on the in-process EVM, which detects a consistent rewrite of the whole log but is not yet an independent, externally operated anchor.

Residual Risk Register

Honest known risks, controls and remaining gaps | v9.1

Status: mitigations listed are implemented to the extent described in CashBridge v9.1; residual risk is not zero. Severity is an engineering prioritisation for this prototype, not a formal quantified risk rating. **Changed since v9:** 04, 05, 06, 11 (controls and residual exposure restated after an internal review), 12 (new).

4. KNOWN RISKS, MITIGATION AND RESIDUAL EXPOSURE

ID / PRIORITY	THREAT	IMPLEMENTED MITIGATION	REMAINING EXPOSURE
01 / HIGH	**Prompt injection / tool hijacking**	Fixed workflow state machine; untrusted strings treated as data; off-policy proposal refused and logged.	Local parsing errors still possible.
02 / HIGH	**Wrong financial answer / hallucination**	Numerical values from local engines; typed inputs; evidence status, audit trail and human release.	Assumptions and forecasts may be wrong.
03 / HIGH	**Cross-tenant or role data leak**	Signed sessions, server-side RBAC, lender release scope and denial tests.	No external IdP/OIDC or enterprise IAM.
04 / HIGH	**Malicious document / unsafe OCR**	Byte-level type check, 10 MB cap; **active-content screen** refuses JS, launch, embedded files, XFA, auto-actions (incl. hex-escaped and object-stream names); bomb cap; encrypted PDFs refused; encrypted vault; sandboxed viewer.	Not an antivirus or content disarm; a malformed file aimed at a viewer bug is not detected.
05 / HIGH	**Tampered / stale / duplicate invoices**	SHA-256 and provenance links; 3-way match; data gate (always on in PRODUCTION); local registry; **consortium register** on an in-process EVM checked at verification; funding refused (409) when another lender holds the invoice or the register cannot be checked.	Other lenders simulated in one process; with CASHBRIDGE_CHAIN=off funding proceeds unchecked (recorded); key custody (HSM) and consortium governance not built.
06 / HIGH	**OTP replay / unauthorised release**	Action- and payload-bound, 120 s, one-use TOTP; 5-attempt cap; Director-only endpoint; denial logs.	Demo OTP secret is public; replay memory is per server process, not a shared store; not institutional MFA.
07 / MED	**Partner API replay / duplicate effect**	Sandbox adapter validates quotes/webhooks; idempotent outbox and replay checks.	No real lender connection certified.
08 / MED	**Confidentiality at rest and in logs**	AES-256-GCM evidence; privacy-filtered/no-store interfaces; export/purge tooling; only commitments and roots on chain.	Local env secret, no KMS/HSM or third-party audit.
09 / MED	**Model shift, bias, false confidence**	Calibrated intervals, domain warnings, published backtests, public distress benchmark, risk caps and human review.	Synthetic SME cases; no real SME credit-default validation.
10 / MED	**Revoked data still held by recipient**	Revoke released-case access and remove internal evidence; record recipient notice.	Files downloaded earlier need recipient deletion.
11 / MED	**Infrastructure & audit compromise**	Fail-closed production mode, local TLS/CSP checks, hash-chained log; **Merkle root anchored** on the in-process EVM (a consistent whole-log rewrite is detected in tests; anchors cannot shrink); anchor failures recorded and shown.	Anchoring is best effort and the chain is controlled by the same operator, so not externally immutable; testnet script not run; no independent pentest.
12 / MED	**Generated contract mistaken for advice or signed**	Fixed clause library (no LLM); DRAFT watermark, NOT SIGNED header, [●] gaps and listed defaults, review checklist; payee call-back clause; no e-signature.	No jurisdiction-specific mandatory clauses; counsel must approve.
13 / MED	**Consortium key exposure**	Commitments are HMAC-SHA256 under a consortium key held off chain; production refuses to start the register without CASHBRIDGE_CONSORTIUM_KEY; demo key in an owner-only runtime file.	Any key holder can test guessed invoices against the register; no HSM, rotation or membership governance.

5. VERIFICATION, SCOPE AND HANDOVER

- **Archived proof:** 28/28 adversarial cases (incl. FIN-04 cross-lender duplicate refused, EVID-04 whole-log rewrite caught by the anchor, DOC-01 hidden-JavaScript PDF refused) and 5/5 agent-governance cases (data/execution_evidence/trust_scorecard.md); 30/30 local production-mode checks (reports/deploy_verification.md); full regression: 1,677 passed, 0 failed, 0 skipped, in 11 min, including the on-chain and 10 real-browser tests (reports/full_pytest_v9_1.txt, with the environment it ran in). These are team-run reports, not third-party certification.
- **On-chain evidence:** transaction hashes, blocks and gas come from the **in-process EVM** (py-evm via eth-tester); they are real EVM executions but **not transactions on a public network**. The testnet deployment script exists (dry-run tested) and has not been run.
- **Important exclusions:** no live money movement, no production bank integration, no certified KYC/AML process, no public-chain deployment, no external penetration test or regulator approval.
- **Safe evaluation:** synthetic case credentials only, Director consent for all outward actions, mock credit decisions, verified and anchored audit log, encrypted evidence viewer.